# Bounding Attacker-Induced Disruption in Exposure-Driven Security Automation: Budgeted, Graph-Aware Guardrails with Exactly Additive Explanations and Verifiable Decision Logs

**Shubhangi Tirpude**
Dept. of Computer Science & Eng
Ramdeobaba University
Nagpur, India
tirpudes@rknec.edu

**Rudra Kathoke**
Dept. of Computer Science & Eng.
Ramdeobaba University
Nagpur, India
rudrakathoke1405@gmail.com

**Nimeesha Shukla**
Dept. of Computer Science & Eng.
Ramdeobaba University
Nagpur, India
nimeeshashukla@gmail.com

**Surabhi Khekale**
Dept. of Computer Science & Eng.
Ramdeobaba University
Nagpur, India
surabhikhekale30@gmail.com

***Abstract*—Many security teams now let exposure feeds trigger credential resets and session revocations with no human in the loop. We treat those feeds as an attack surface: an adversary who plants or amplifies fake records can make the defender's own automation lock out legitimate users. This paper formalizes that threat and describes a guardrail with three parts. The protected set comes from an identity's position in the access graph, each action is priced by the disruption it would cause downstream, and autonomous execution is allowed only inside sliding-window budgets that are split by source credibility. Scoring mixes rules with a learned model and yields an exactly additive explanation, and every decision goes into a verifiable log. On synthetic organizations (eight attacker strategies, six defenses, 30 seeds), the guardrail cut attacker-induced disruption by 92.7% against rate limiting (463 vs. 6,314 cost units) and by 96.7% against naive auto-execution, and it reduced autonomous actions on critical identities from 148–165 to 4.2 per run. The cost was a 15.5% relative drop in remediation of rare, material compromises (success rate 0.505 vs. 0.598), and analysts, not automation, approved 88% of the disruption that remained. A second simulator adds cost-only and Agent-Lock-style baselines and sweeps analyst behavior: the advantage over a static list holds up to an analyst error rate of 0.30, while remediation falls to 78.6% at 6 reviews per day and to 72.5% at a 24 h approval delay. The explanation matched the final score within $1.2 \times 10^{-5}$ points, and an externally witnessed Merkle head detected every tampering attempt. Validation on real data is still pending; code and tests accompany the paper.**

***Index Terms*—security orchestration, data poisoning, attack graphs, explainable AI, tamper-evident logging**

## I. Introduction

### A. Background and Motivation

A security operations center (SOC) now receives a constant stream of exposure intelligence: credentials leaked in breach dumps, secrets that appear on paste sites, and records sold or shared through commercial and open feeds. To keep up, many teams connect these feeds to orchestration platforms that reset credentials, revoke sessions or disable accounts without waiting for a person. Each of those actions costs availability. Disabling a service account or an executive's login can halt business processes, and the cost is incurred even when the exposure record turns out to be wrong.

Two observations make this risky. The first is that exposure is not compromise. In Google's measurement of stolen credentials, only 7% of third-party-breach victims had their current password exposed, against 12% of keylogger victims and 25% of phishing victims [1]. The second is that nobody vouches for what a feed contains. Have I Been Pwned flags entries as verified or fabricated, which implies that unverified and invented breaches circulate [2]. Work on fabricated threat reports points the same way: transformer models can generate fake threat reports that professional threat hunters judged as likely to be true as authentic ones [3], and misleading text injected into data sources can induce false positives in automated pipelines [4]. A 2026 SANS white paper names the resulting attack Autonomous Defense Induced Disruption (ADID) and demonstrates it against one commercial product with 18 test users [5]. It is a white paper, not a peer-reviewed article.

### B. Problem Statement and Research Gap

Surveys of SOC alert triage observe that most methods work from alert-level criteria [6], [7]. Asset-intelligence work separates intrinsic exposure from contextual importance, including blast radius [8], but does not consider poisoned inputs or the safety of the response. Agent-Lock formalizes a Tier-0 non-disruption property for LLM agents using time-scoped blast-radius budgets [9]; it governs the plans an agent proposes, not exposure-driven playbooks. FeedRank ranks threat-intelligence feeds in a tamper-resistant way [10], and RADAMS defends analyst attention against informational denial of service [11]. Neither limits what automated response may do once a forged record gets through. To the best of our knowledge, as of October 2026, no earlier study evaluates graph-aware, budgeted guardrails for exposure-driven response against an adversarial feed.

Sliding-window admission control and rate limiting are standard tools. What we contribute is deriving the protected

set from the graph, splitting the budget by source credibility, and measuring the remediation this costs against an adaptive feed adversary. Poisoning attacks on learning-based security systems [12] target the model or its training data. The forged records studied here leave the model alone and aim at the response policy that consumes its output.

### C. Objectives and Research Questions

We study the safety layer of AEGIS-X, a prototype for exposure-driven triage and response, and ask three questions. **RQ1** (real labels): does context-aware hybrid triage beat CVSS, EPSS and KEV baselines when probabilities are calibrated? This remains open (Section VI). **RQ2** (headline): when the feed is poisoned, how much disruption can an adversary cause against each defense, and how much remediation does each defense give up? **RQ3**: can the score be explained with exact additivity and stable attributions, and will the log expose tampering?

One hypothesis was stated before the pilot analysis; its thresholds are illustrative and were not frozen in a dated commit. **H2**: the proposed guardrail reduces attacker-induced disruption by at least 50% relative to rate limiting while retaining at least 80% of naive auto-execution's remediation success. Hypotheses for the revision experiments (sensitivity and added baselines) were frozen in `HYPOTHESES.md` (commit 018d18e, 22 Oct 2026); parameters were then aligned with the code in commit 7e99f0a, before the runs in commit aa089bc.

### D. Contributions and Organization

- **C1.** A threat model for exposure-driven automated response, and a non-disruption invariant with proofs (Propositions 2 and 3).
- **C2.** A protected set read from graph structure, a model that prices disruption, and a budget split by source credibility, supported by repeat elision, a mildest-first action ladder and post-action diagnosis.
- **C3.** A pilot with eight attackers and six defenses; ablations over guardrail tier, action space, scorer noise, injection intensity, graph error and topology; and a second-simulator study of added baselines and analyst sensitivity (30 seeds, confidence intervals, paired tests).
- **C4.** An exactly additive explanation of a rule, model and MFA score, with graph counterfactuals, committed to a tamper-evident log.
- **C5.** A reproducible artifact (simulator, 23 passing tests, figure scripts) and an audit of the gap between the simulator and the integrated prototype.

Section II reviews related work, Section III gives the design, Section IV reports results, Section V discusses them and their limits, and Section VI concludes.

## II. Related Work and Literature Review

**SOC triage.** One systematic survey reviews the criteria and methods of alert prioritization [6], and another covers alert screening and fatigue mitigation [7]. GUIDE supplies about one million incidents with analyst triage labels [13]. ExTriage combines an ensemble classifier, SHAP, counterfactual explanations and a study with 24 analysts [14]. All of these rank alerts that detectors have already produced. We start one step earlier, at the exposure feed, and ask whether the actions it triggers are safe.

TABLE I
Positioning against the closest prior work

| Work | What it does | Difference here |
|---|---|---|
| Asset intelligence [8] | Exposure vs. contextual importance (blast radius) | We decouple severity from source reliability and add feed poisoning, guardrails and verifiable logs |
| Agent-Lock [9] | Tier-0 non-disruption for LLM agents | Deterministic, graph-derived protection for exposure-driven SOAR; adaptive feed adversary; lost remediation measured |
| ADID [5] | Induces containment of legitimate users (one product, 18 users) | We formalize the feed-poisoning variant, quantify defenses and give a bound |
| CTI poisoning [4] | Misleading text induces false positives in CTI extraction | We bound the response policy instead of filtering the input |
| GUIDE [13] | ∼1M incidents with triage labels | Planned real labels for RQ1; no guardrail evaluation |
| ExTriage [14] | SHAP, counterfactuals, analyst study | Exact additivity over rule, model and MFA, with graph counterfactuals |
| Merkle logs [21], [22] | Tamper-evident history trees | Standard part; external witness made explicit |
| Poisoning [12] | Poisoning and evasion of learned detectors | Targets the model; here forged records target the response policy, bounded by budgets |

**Exposure and graph-based risk.** EPSS estimates the probability that a vulnerability will be exploited [15], and the CISA KEV catalog offers a curated binary signal [16]. Attack-graph research models multi-step intrusion [17], and several impact metrics describe how far a compromise can spread: lateral-movement impact [18], privilege-weighted reach [19] and crown-jewel analysis [20]. We use a most-probable-path reach and treat these metrics as baselines.

**Safe automated response.** Agent-Lock bounds LLM-agent actions with blast-radius budgets and is evaluated on a 50-case synthetic suite [9]. AIR approaches agent safety from the incident-response side [23]. Neither addresses a deterministic playbook that reacts to forged exposure records, and AEGIS-X contains no LLM agent.

**Data poisoning.** Adversarial machine learning has studied training-time poisoning and test-time evasion of learning-based security systems for more than a decade; Biggio and Roli survey the field [12]. Closer to our setting, recent work on threat intelligence shows that generated fake reports can pass for genuine ones with professionals [3] and that injected text can raise false-positive rates in automated pipelines [4]. Those efforts clean the input or protect the human. The attack in this paper needs no change to any model: forged exposure records push a correct scorer toward harmful actions. Our defense therefore limits what the response policy may do, instead of making a classifier more robust.

**Explainability and logging.** SHAP is widely used in security ML [24], [25], but Shapley-based importance has known limits when features are correlated [26]. Crosby and Wallach describe history trees with membership and consistency proofs [21], and

TABLE II
CLOSED ACTION SPACE

| Action | Kind | $\kappa$ | $\rho$ | Reversible |
|---|---|---|---|---|
| revoke_sessions | state-changing | 0.2 | 0.55 | yes |
| reset_credential | state-changing | 0.5 | 0.90 | yes |
| disable_account | state-changing | 1.0 | 0.99 | slowly |
| escalate, ignore/elide | queue write, no-op | 0 | n/a | n/a |

Certificate Transparency standardized Merkle logs with signed heads [22]. Arp et al. catalog evaluation pitfalls in security ML [27].

## III. Proposed Methodology and System Design

### A. Threat Model and Objective

An exposure event $e = (i, s, y, d, t, v, k)$ concerns identity $i$ and comes from source $s$ of type $y$. It carries data classes $d$, arrives at time $t$, has verification flag $v$ and corroboration count $k$. An action $a$ has severity $\kappa_a$ and effectiveness $\rho(a)$. Let $X_i \in \{0, 1\}$ indicate whether identity $i$ is truly compromised, and let $C(a, i) \geq 0$ be the disruption cost of executing $a$ on $i$. The attacker can inject or amplify records in ingested feeds, choose victims and timing, forge corroboration with capacity $q$ (the share of the high-credibility budget it can consume), and knows the guardrail design. It cannot modify the platform or the database, cannot obtain the signing key, cannot compromise the identity provider, and cannot alter the graph (graph poisoning is future work). Its goals are G1, maximize criticality-weighted disruption; G2, trigger an autonomous action on a protected identity; and G3, flood analysts so that a real incident stays hidden. The defender maximizes timely remediation subject to a disruption budget $B$ per window $W$ and a protected set $T_0$:

$$\max R = \sum_i \mathbf{1}[X_i = 1, \text{ remediated within SLA}]$$
$$\text{s.t.} \sum_{a \in W} C(a, i_a) \leq B, \quad \text{no autonomous action on } T_0. \tag{1}$$

### B. System Architecture

AEGIS-X has five stages (Fig. 1): ingestion and scoping; topology (weighted graph, impact, protected set, cost); scoring and explanation; the guardrail; and execution with audit. Only state-changing actions pass through the guardrail, while read-only tools are unrestricted. Because the action space is closed, every possible action has a price and the invariant can be checked (Table II). The reference implementation maps one module to each block: organization generator, simulator, explanation engine and log.

### C. Graph Reach and Impact

The graph $G = (N, E)$ has identities and assets as nodes. Each edge carries a traversal probability $p_e \in (0, 1]$ that depends on privilege and protocol. MFA scales the edge a login crosses first by 1.0 (none), 0.6 (SMS), 0.4 (TOTP) or 0.15 (FIDO). The most-probable-path reach from identity $i$ to crown jewel $c$ is

$$r(i, c) = \max_{\pi: i \to c} \prod_{e \in \pi} p_e, \tag{2}$$

computed by Dijkstra with weights $-\ln p_e$. With crown-jewel weights $w_c$, impact is

$$I(i) = \sum_c w_c \, r(i, c) \Big/ \sum_c w_c \in [0, 1]. \tag{3}$$

Unlike reachable-node counts with fixed constants, $I(i)$ does not saturate and it handles cycles. If edge events are independent, it is a lower bound on the true reach probability (Proposition 4), which we check against Monte Carlo in the test suite.

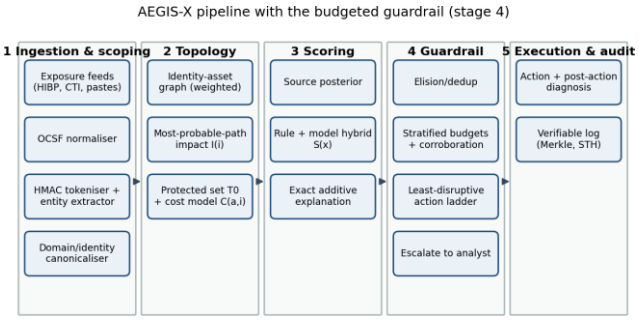



Fig. 1. AEGIS-X pipeline. Only state-changing tools (revoke sessions, reset credential, disable account) pass through the guardrail; read-only tools are unrestricted.

### D. Source Reliability

A record's probability of matching a currently valid credential starts from a source-type prior, in the spirit of [1] (simulator values: breach 0.05, paste 0.03, keylogger 0.12, phishing 0.25). The prior is multiplied by 1.6 if the record is verified, by 0.15 if it is flagged as fabricated, and by $1 + 0.25(k - 1)$ for corroboration count $k$; the result is capped at 0.9. A record counts as *credible* if $k \geq 2$, it is verified, or its posterior is at least 0.30. To avoid confusion with predictive confidence, we call this quantity source reliability.

### E. Hybrid Score and Exactly Additive Explanation

The score combines a linear rule $R(x) = 10^{\sum_j w_j f_j}$ (weights sum to one), a classifier probability $p(x)$ and an MFA modifier $m(x)$:

$$S(x) = \alpha R(x) + (1 - \alpha)\, 100\, p(x) - m(x), \tag{4}$$

with $\alpha = 0.40$ and $m = 12$ when MFA is enforced. Let $\bar{f}$ be the mean of a background sample and $\phi_j$ the exact interventional Shapley values of $p$ in probability space, so that $\sum_j \phi_j = p(x) - \mathrm{E}[p]$. Define

$$\Phi_j = \alpha\, 10^{w_j (f_j - \bar{f}_j)} + (1 - \alpha)\, 100\, \phi_j,$$
$$\text{base} = \alpha R(\bar{f}) + (1 - \alpha)\, 100\, \mathrm{E}[p]. \tag{5}$$

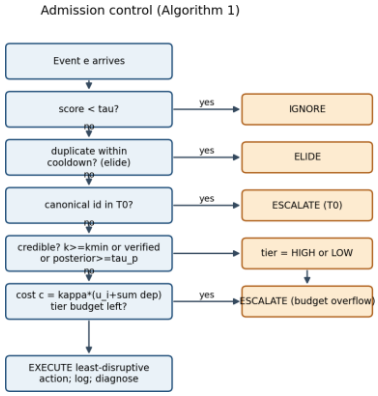



Fig. 2. Admission control flow (Algorithm 1). Protection and budget checks are the only paths to autonomous execution.

**Proposition 1 (exact additivity).** $S(x) = \text{base} + \sum_j \Phi_j - m(x)$. The MFA term appears as its own signed bar, and any clipping to $[0, 100]$ appears as an explicit residual (proof in the Appendix). With nine factors, the Shapley values come from exact enumeration of $2^9 = 512$ coalitions, about 76 ms per incident in the Python reference. TreeSHAP on log-odds, as used in a legacy display, is not additive on the final score, because the score also mixes a rule part, a probability and an MFA effect.

### *F. Protected Set and Disruption Cost*

The protected set is derived from attributes and graph position, never from names: $T_0 = \{i : i$ is in an identity-provider admin group, or reach to Tier-0 assets $\geq 0.25$, or dependent weight $\geq 60$, or $I(i)$ is in the top 3%$\}$. Before any membership test, the identity string is normalized (Unicode NFKC, lower case, trimmed, plus tags stripped), checked against the home domain and resolved through an alias table. Lookalike characters therefore fail to match, and the event is treated as out of scope. The disruption cost is

$$C(a, i) = \kappa_a \left( u_i + \sum_{n \in \text{Dep}(i)} w_n \right), \qquad (6)$$

where $u_i$ is the identity's own business weight (user 1, admin 4, executive 10, service account 1) and $\text{Dep}(i)$ is the set of assets that depend on $i$ (large for service accounts). The planner prefers the least disruptive action that meets the needed effectiveness: a posterior of at least 0.30 calls for a reset, otherwise a session revocation.

### *G. Credibility-Stratified Admission Control*

Events are staged by credibility and autonomy. Each one is scored, then admitted (`AUTO_EXEC`), escalated to an analyst (`ESC_*`) or ignored. Credible events draw on a high-credibility budget $B_{\text{high}}$, which is kept apart from the budget $B_{\text{low}}$ used for everything else. Fig. 2 and Algorithm 1 show the logic.

**Proposition 2 (non-disruption invariant).** If admission is atomic and canonicalization, $T_0$ and Dep are correct, then for any injection sequence no autonomous action targets $T_0$, and the total admitted cost in any window of length $W$ is at most $B_{\text{high}} + B_{\text{low}}$.

**Proposition 3 (stratified bound).** Let $q \in [0, 1]$ be the largest share of $B_{\text{high}}$ that forged high-credibility events can consume. Then, per window, attacker-induced disruption is bounded by $B_{\text{low}} + q\, B_{\text{high}}$, and at least $(1 - q)B_{\text{high}}$ stays reserved for genuine high-credibility events. We treat $q$ as an experimental parameter because it depends on how costly corroboration is to forge. Propositions 2 and 3 hold by construction, conditional on correct Canon, $T_0$ and Dep. The empirical question, taken up in Section IV, is what they cost in analyst load, delay and lost remediation.

**Algorithm 1** Stratified admission control Admit($e$, $t$)

**if** $e$.score $< \tau$ **then**
  **return** IGNORE
**end if**
**if** elision on **and** $t -$ last_touch[$id$] $<$ cooldown **then**
  **return** ELIDE
**end if**
$i \leftarrow$ Canon($e$.raw_identity); **if** $i = \emptyset$ **return** IGNORE
**if** $i \in T_0$ **then**
  **return** ESCALATE($T_0$)
**end if**
$a \leftarrow$ least-disruptive action for $e$.posterior; $c \leftarrow C(a, i)$
tier $\leftarrow$ HIGH if credible($e$) else LOW
$H \leftarrow$ cost admitted in this tier within $(t - W, t]$
**if** $H + c \leq B$[tier] **then**
  execute($a$, $i$); record($t$, $c$); schedule verify at $t + 1$ h
  **return** ADMIT
**else**
  **return** ESCALATE(BUDGET)
**end if**

### *H. Elision, Diagnosis, Counterfactuals and the Log*

Repeats of the same record (replays, or copies arriving from several sources) are merged during a 12 h cooldown. A real exposure then draws on the budget once, and a slow-drip attacker cannot keep buying new actions against one target. One hour after an autonomous action the identity is re-checked; if the compromise persists, the action steps up (revoke, reset, disable) under the same budget. A stall rule for bursts from one source cluster and for escalate/admit oscillation is specified but not simulated.

For an incident with $S(x) \geq \tau$, the counterfactual planner enumerates every subset of five remediation steps (cost in brackets): enforce MFA [1.0], rotate credential [1.5], patch CVE [2.0], reduce privilege [2.5] and revoke edge [3.0]. It returns the cheapest subset whose recomputed score falls below $\tau$. Validity holds by construction, because the score is recomputed.

A decision record stores the actor, time, action, resource, severity before and after, the explanation hash, and the model and configuration hashes. Its log leaf is SHA-256(`0x00`$\|\|$ canonical JSON), and an internal node is SHA-256(`0x01`$\|\|$left$\|\|$ right). The tree head is signed with Ed25519, and inclusion and consistency proofs follow RFC 6962 [22] and RFC 9162 [28]. Heads must be published somewhere the operator cannot rewrite them; otherwise an insider who holds the key can rebuild the log.

### I. Implementation and Prototype Status

The reference implementation (Python 3.12 with NumPy, NetworkX, XGBoost, cryptography and pytest; 1,348 lines) produces every number in Section IV. Its 23 tests pass in 9.4 s on one core, and the roughly 5,700 simulated runs, the tests, the log benchmarks and all figures regenerate in about ten minutes on one core.

The integrated web prototype was audited separately at one commit, and we did not re-run those checks on the current working tree. The audit found, among other issues, a scripted guardrail experiment, a count-based gate that allowed 384 autonomous actions in 24 h under forged evidence, constant dependent counts inside the gate, a predictable login token, a forgeable fallback post-quantum signer, and a README score contradicted by its own result files. For these reasons nothing from the prototype enters the results, and we claim no authentication, post-quantum or compliance property.

## IV. Experimental Results and Evaluation

### A. Experimental Environment

**Organizations.** Each seed builds an organization of 2,000 identities (1,850 users, 100 service accounts, 40 admins, 10 executives) plus 3 Tier-0 assets, 8 crown jewels, 66 applications and 133 servers, roughly 2,210 nodes and 8,500 edges. MFA covers 70% of identities and the topology is hierarchical. We also run a flat, denser topology with more cycles (20 seeds). The ground-truth critical identities are the executives, the admins and the service accounts with dependent weight of at least 60 (about 92 per organization); the defender never sees this set.

**Feed and scorer.** The feed runs for 720 h at 3 records per hour, with 20% duplicates and a source mix of 60% breach, 25% paste, 8% keylogger and 7% phishing. Arrival lag is log-normal with a 72 h median, an assumption that awaits a real lag study. The scorer is $s = 100(0.40\, I_{\text{norm}} + 0.35 \min(1, \text{posterior}/0.5) + 0.15\,\text{freshness} + 0.10\,\text{KEV}) + \mathcal{N}(0, \sigma^2)$ with $\sigma = 5$. A true compromise is *material* when the compromised identity's true impact is at or above the 92nd percentile of impact in its organization; remediating such a compromise within the 24 h SLA counts toward SR. The threshold $\tau = 34$ was calibrated on the benign stream to reach about 69% recall of material compromises, and all defenses share it.

**Attackers.** We use eight strategies. S1 targets random identities, S2 the highest-impact ones, and S3 service accounts with many dependents. S4 sends case and alias variants of protected names. S5 forges credibility ($q = 1$) against S2 targets. S6 drips records just under the rate limit, S7 times bursts to coincide with real incidents, and S8 is an adaptive white-box attacker that aims at high-impact identities outside the defender's $T_0$ with $q = 1$. Injection defaults to 10% of feed volume, and other injected records forge credibility with $q = 0.25$.

**Defenses and analyst model.** Table III lists the six defenses. The analyst pool clears 12 escalations a day in score order. It catches 90% of true compromises and wrongly acts on 4% of ordinary events and 12% of credible forgeries; actions on executives wait 8 h for sign-off. These numbers are assumptions, not measurements, and B4's residual disruption is dominated by them. Section IV-M varies them in a second simulator.

TABLE III
Defenses compared and key parameters

| ID | Defense | Mechanism |
|---|---|---|
| B0 | Auto-execute | Disable account whenever score $\geq \tau$ |
| B1 | Static list | Exact-match list of 4 protected names, then auto-reset |
| B2 | + corroboration | B1 plus corroboration required for autonomy |
| B3 | Rate limit | B1 plus at most 15 actions per 24 h |
| B4 | Proposed | Canonicalization, graph-derived $T_0$, stratified budgets ($B_{\text{low}} = 6$, $B_{\text{high}} = 20$ per 24 h), ladder, elision, diagnosis |
| B5 | Recommend-only | Every event goes to a finite analyst queue |

Baselines B6, B7 and B0-mild are evaluated in a separate simulator (Section IV-L).

TABLE IV
Attacker-induced disruption $D$ (cost units over 30 days; 10% injection; lower is better)

| Strategy | B0 | B1 | B2 | B3 | B4 | B5 |
|---|---|---|---|---|---|---|
| S1 random | 860 | 425 | 133 | 422 | 62 | 27 |
| S2 high impact | 16,287 | 8,134 | 2,263 | 7,374 | 461 | 513 |
| S3 service accts | 22,003 | 10,993 | 3,125 | 9,993 | 536 | 654 |
| S4 alias bypass | 4,772 | 2,385 | 737 | 2,233 | 154 | 158 |
| S5 forged ($q$=1) | 16,485 | 8,224 | 8,216 | 7,418 | 821 | 924 |
| S6 slow drip | 33,070 | 16,530 | 4,691 | 16,404 | 788 | 937 |
| S7 burst | 13,084 | 6,534 | 1,866 | 4,290 | 347 | 434 |
| S8 adaptive | 5,238 | 2,619 | 2,616 | 2,379 | 532 | 315 |
| Mean | 13,975 | 6,981 | 2,956 | 6,314 | **463** | 495 |
| 95% CI | 12,764–15,245 | 6,371–7,610 | 2,664–3,257 | 5,731–6,952 | 427–498 | 451–537 |

### B. Evaluation Metrics and Statistics

Disruption $D$ is the criticality-weighted cost of executed actions on non-compromised identities that are attributable to attacker records (autonomous plus analyst-approved). Violations are autonomous actions on ground-truth critical identities. The success rate (SR) is the share of material true compromises (about 19 per run) remediated within 24 h. We also report the overflow rate (24 h windows containing at least one budget or rate-limit escalation), escalation load per day, and the precision of autonomous actions. All defenses see the same event stream for a given seed. Confidence intervals are 2,000-resample bootstrap intervals over 30 seeds, and tests are Wilcoxon signed-rank with Holm correction across 40 comparisons.

### C. Main Result: Attacker-Induced Disruption (RQ2)

Table IV and Fig. 3 give the main result. Against B0, B1, B2 and B3, B4 lowered $D$ by 96.7%, 93.4%, 84.4% and 92.7%, respectively (463 vs. 6,314 cost units for B3). All 32 comparisons of B4 against B0–B3 are significant after Holm correction (adjusted $p < 0.001$). For S4 the difference between B4 and B5 is not significant ($p = 0.67$). B5 wins on S1 and S8; B4 wins on S2, S3, S5, S6 and S7. Autonomous actions on ground-truth critical identities per run were 165.0 (B0), 165.0 (B1), 61.3 (B2), 148.2 (B3), 4.2 [2.9, 5.7] (B4) and 0 (B5).

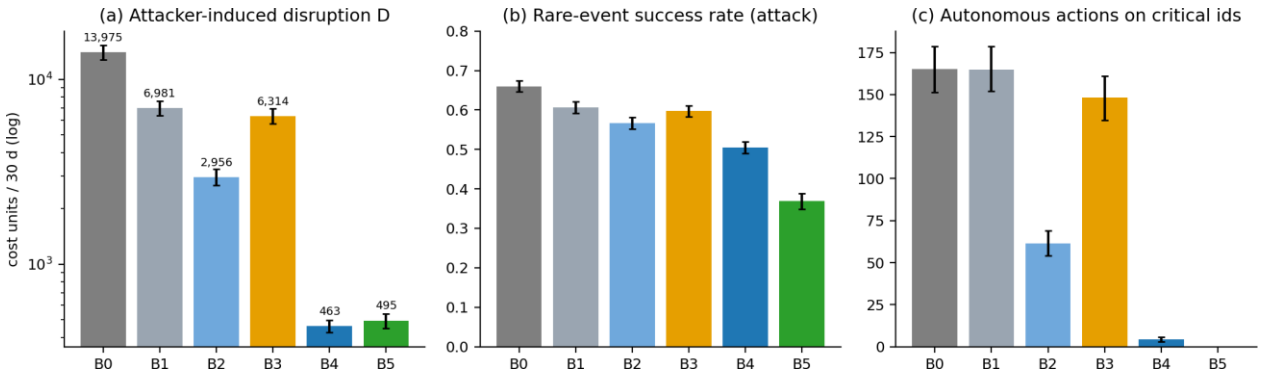



Fig. 3. (a) Attacker-induced disruption (log scale), (b) rare-event remediation success rate under attack, and (c) autonomous actions on ground-truth critical identities, per defense; means with 95% bootstrap CIs over 30 seeds.

TABLE V
REMEDIATION AND WORKLOAD (SR ON ABOUT 19 MATERIAL TRUE COMPROMISES PER RUN; 572 OVER 30 SEEDS)

| Def. | SR, attack [95% CI] | SR, none | Benign auto cost | Esc./day | PPV |
|---|---|---|---|---|---|
| B0 | 0.660 [0.646, 0.674] | 0.65 | 4,551 | 0.0 | 0.069 |
| B1 | 0.607 [0.592, 0.621] | 0.60 | 2,241 | 0.1 | 0.069 |
| B2 | 0.567 [0.552, 0.581] | 0.56 | 1,254 | 2.3 | 0.068 |
| B3 | 0.598 [0.583, 0.612] | 0.60 | 2,241 | 0.1 | 0.069 |
| B4 | 0.505 [0.490, 0.520] | 0.52 | 50 | 2.4 | 0.175 |
| B5 | 0.369 [0.348, 0.389] | 0.64 | 0 (+125 human) | 86.1 | n/a |

TABLE VI
BUDGET SCALE UNDER THE ADAPTIVE ATTACKER S8

| Scale | B4 $D_{auto}$ | B4 SR | B4 overfl. | B4 esc/day | B3 $D_{auto}$ | B3 SR |
|---|---|---|---|---|---|---|
| 0.125× | 31 | 0.52 | 0.99 | 7.4 | 402 | 0.53 |
| 0.25× | 47 | 0.52 | 0.98 | 6.7 | 775 | 0.56 |
| 0.5× | 129 | 0.53 | 0.97 | 6.3 | 1,481 | 0.58 |
| 1× | 310 | 0.52 | 0.94 | 5.6 | 2,350 | 0.61 |
| 2× | 712 | 0.53 | 0.82 | 4.6 | 2,619 | 0.61 |
| 4× | 1,340 | 0.54 | 0.49 | 3.2 | 2,619 | 0.61 |

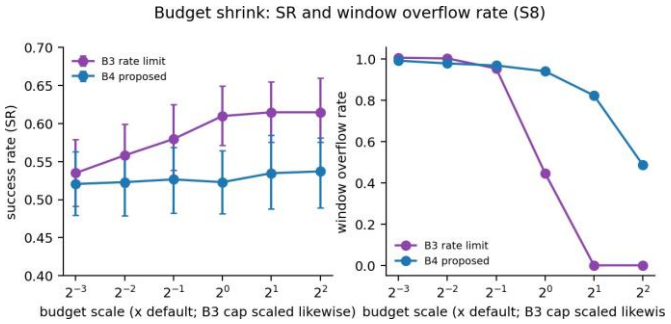



Fig. 4. Success rate and window-overflow rate as the budget shrinks (S8).

Three caveats apply. (i) The human is the weak link: 88.1% of B4's residual $D$ is analyst-approved, and autonomous disruption under B4 averages only 55 units. (ii) Action severity confounds B0 against B1, since B0 uses the most severe action. A second simulator (Section IV-L) restricts B0 to revoke sessions ($\kappa = 0.2$). That cuts B0's $D$ to one fifth, as $\kappa$ implies, yet B0 still reaches 20.0 on S2 against 0.0 for B4, so severity alone does not explain the gap. The pilot simulator itself was not rerun with this control. (iii) S2 and S5 are easy by construction, because they target identities that already sit inside the graph-derived $T_0$. S8 is the fair stress test: B4 reaches 532 against 2,379 for B3, a 77.6% reduction.

### D. Remediation and Workload

Table V compares remediation and workload. B4 retains 76.5% of B0's success rate and 84.5% of B3's. The success-rate half of H2 (at least 80% of B0) is therefore *not* met, while the disruption half (at least 50% below B3; observed 92.7%) is met. B5 keeps SR at 0.64 without attacks but collapses when attacks flood its queue (S7: 0.13, S6: 0.22, with 86–98 escalations per day), whereas B4's SR stays between 0.46 and 0.52 under every strategy. Autonomous precision is low for every defense, because exposure is rarely compromise; B4's is about 2.5 times higher because it acts on fewer, higher-impact records.

### E. Budget Shrink: Success Rate and Window Overflow

We shrank the budget from 0.125× to 4× under S8 (B3's count cap scaled likewise); Table VI and Fig. 4 show the trade. B4's SR barely moves (0.52 to 0.54) while its autonomous attacker-induced disruption grows about 43-fold. The SR loss of B4 relative to B3 is therefore not caused by the budget; Section IV-H locates it.

### F. Guardrail Tiers (Cumulative Ablation)

Table VII and Fig. 5 add one control at a time. Against the naive high-impact attacker, graph-derived protection does most of the work (S2 falls from 2,263 to 513). Against the adaptive attacker that stays outside $T_0$, the cost budget does (S8 falls from 2,616 to 705). Stratification helps a little more (S8: 705 to 578), and the ladder and the elision-plus-diagnosis step each add another 4–8%. For S4, canonicalization removes most of the benefit of alias bypass, yet the ladder raises ground-truth violations from 26 to 39: milder actions are cheap, so the

TABLE VII
CUMULATIVE GUARDRAIL TIERS: S2 (NAIVE) AND S8 (ADAPTIVE)

| Tier (cumulative) | S2 $D$ | S2 SR | S8 $D$ | S8 SR |
|---|---|---|---|---|
| L0 threshold only | 16,287 | 0.65 | 5,238 | 0.67 |
| L1 + static list | 8,134 | 0.60 | 2,619 | 0.61 |
| L2 + corroboration | 2,263 | 0.57 | 2,616 | 0.58 |
| L3 + graph $T_0$, canonical ids | 513 | 0.50 | 2,616 | 0.55 |
| L4 + cost budget (single tier) | 513 | 0.50 | 705 | 0.55 |
| L5 + stratified budgets | 513 | 0.53 | 578 | 0.55 |
| L6 + least-disruptive ladder | 513 | 0.51 | 556 | 0.54 |
| L7 + elision, diagnosis (= B4) | 461 | 0.51 | 532 | 0.52 |

TABLE VIII
EXPLANATION AND LOG RESULTS (RQ3)

| Metric | Result |
|---|---|
| Additivity error | max $1.2 \times 10^{-5}$, mean $3.8 \times 10^{-6}$ points (200 incidents) |
| Legacy log-odds×40 gap | mean 47.8, max 132.2 points |
| Stability (Kendall $\tau$, 10 retrains) | exact 0.731 (5th pct 0.444); log-odds TreeSHAP 0.676 (0.389) |
| Counterfactual validity | 40 of 40 high-score incidents valid; median 1 action (enforce MFA) |
| Latency | 76 ms per incident (Python) |
| Tamper detection (200 trials/attack) | 100% with external head; 0% without |

budget lets through more actions on critical identities that $T_0$ misses.

### G. Forging Capacity, Weaker Scorers and Action Space

**Forging capacity.** With the adaptive attacker and free capacity $q$, the daily autonomous cost from low-credibility forgeries stayed within $B_{\text{low}} = 6$ (about 2.3 per day at $q = 0$, falling to zero at $q = 1$ as forgeries move into the credible tier). Credible-tier cost rose from 0 to about 10.3 per day as $q$ went from 0 to 1 (bound $B_{\text{high}} = 20$). The largest cumulative autonomous cost in any 24 h window across the sweep was 25.9, just under the total bound of 26. The bounds held, although peak windows came close. Under S2, total disruption grows from 289 ($q = 0$) to 920 ($q = 1$), all human-approved.

**Weaker scorers.** At scorer noise $\sigma = 5/15/30$, B3's SR is 0.61/0.59/0.48 and its escalations rise from 1.4 to 16.0 per day, while B4's SR stays at 0.52/0.52/0.49 with a flat workload of about 5.5 per day. B4's benign false-positive cost rises from 30 to 140, while B3's moves from 1,985 to 1,022 as noise grows; B4 stays far lower at every noise level.

**Action space.** With a disable-only action set, B4's benign false-positive cost is 47.8; with the full ladder it is 29.8, a reduction of about 38%. Autonomous attacker-induced disruption rises a little (173 to 310), since a cost budget lets in more cheap actions; it limits total cost, not the count of actions.

### H. Trajectories and Failure-Stage Attribution

Under every defense, 86.8% of events are ignored. Of the remainder, B4 sends 3.2% to autonomous execution, 7.4% to protected-set escalation, 0.6% to budget escalation and 2.0% to elision; B0 acts autonomously on 13.2% and B3 on 11.5% (with 1.6% rate-limit escalations). On the flat topology B4 gives the same picture (5.0% autonomous, 7.7% protected-set escalations) and the same ordering, although SR is higher for every defense there, so absolute SR should not be read as topology-independent.

Fig. 6 attributes missed material compromises (572 over 30 seeds, no attack). A third of the misses in every threshold defense (195 of 572) are scorer misses, independent of the guardrail. What B4 loses beyond that comes from manual handling of protected identities (28) and analyst misses (37); the budget accounts for only 3. Post-action diagnosis wins back events that B1 loses to ineffective actions (31 versus 2). Protection moves some true compromises to humans, who are slower and fallible, and diagnosis pays part of that back.

### I. Robustness and Scalability

When 10, 20 and 30% of edges are missing from the defender's graph, the rank correlation of impact with the true values falls to 0.86, 0.73 and 0.58, yet $T_0$ recall stays at 96.3–96.6% (attribute criteria carry it) and B4's SR moves only from 0.52 to 0.50. Raising injection from 1% to 25% of the feed lifts B4's $D$ from 91 to 999, against 491 to 15,403 for B0. A 40,000-identity organization (44,010 nodes, 171,658 edges) took 4.4 s to build with impact and $T_0$, and 0.56 s at 10,000 identities. The derived $T_0$ covers 95.7% of critical identities (precision 84.1%): admins 100%, critical service accounts 100%, but executives only 57.5%, because their graph position is less extreme. An attribute-based VIP tag would close this gap.

### J. Explanation and Log (RQ3)

Table VIII summarizes RQ3. The decomposition reproduced the score to within $1.2 \times 10^{-5}$ points, the round-off of float32 model predictions, so we set the tolerance at $10^{-4}$. The legacy log-odds×40 display left a mean gap of 47.8 points (maximum 132.2). Stability is modest: mean Kendall $\tau$ is 0.731 for the exact attribution against 0.676 for log-odds TreeSHAP, with a wide lower tail. Factors are only mildly correlated (largest VIF 2.88), which limits but does not remove the known caveats [26]. Fig. 7 shows the residual comparison.

Appends ran at about 90,000 events per second in Python (one million events in 11.1 s). Inclusion proofs had exactly $\log_2 N$ hashes (10, 12, 14, 16 for $N = 2^{10}$ to $2^{16}$; 320–512 bytes) and verified in 6.5–9.7 $\mu$s. We ran 200 trials per attack (modify, delete, reorder, insert, truncate, rebuild everything). With an externally witnessed head every attack was caught; a verifier that trusts only the log's own re-signed head caught none. An external witness is therefore mandatory.

### K. Test Suite

The 23 tests pass. They cover weight sums and score bounds; monotonicity of the rule score over $10^5$ random inputs; scope tricks and canonicalizer fuzzing, with no misses and no false in-scope matches; hand-computed graphs, cycles and edge-addition monotonicity; the lower-bound property of impact against Monte Carlo; exact additivity; counterfactual validity; zero autonomous actions on the derived $T_0$ over more than

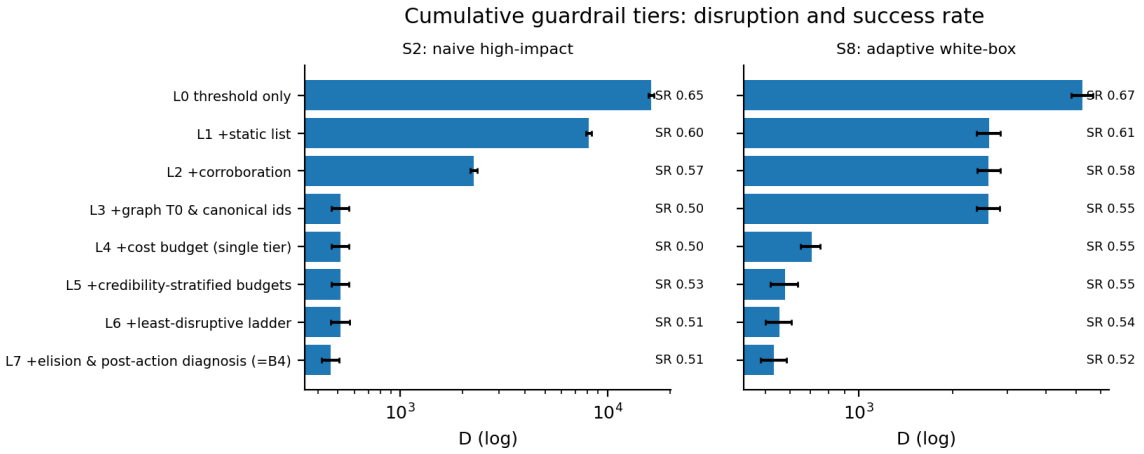



Fig. 5. Cumulative guardrail tiers: disruption (log scale) and success rate for S2 and S8.

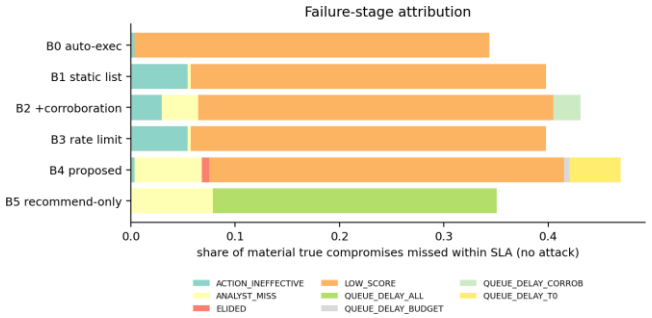



Fig. 6. Failure-stage attribution for material true compromises (no attack).

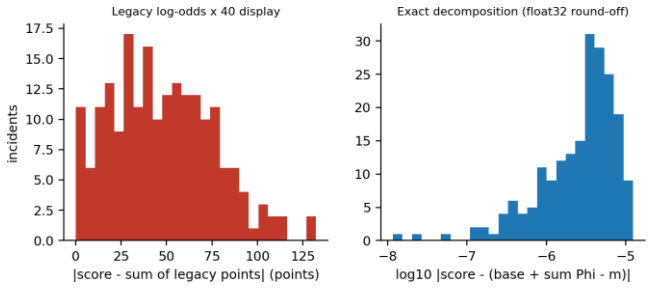



Fig. 7. Additivity: residual of the exact decomposition versus the legacy log-odds×40 display.

160,000 simulated events; cumulative autonomous cost per 24 h within the bound of 26; bypass of the exact-match list versus a holding canonical check; replay idempotence; and eight log tests (tamper detection, inclusion for all indices up to 300 leaves, consistency for all pairs up to 70, domain separation). Not yet implemented: ingestion fuzzing, tokenizer leakage, protected-set recall on real graphs, calibration and leakage audits, explanation fidelity, the analyst-queue model in the main simulator (a second simulator covers it in Section IV-M), API security and the end-to-end scenario.

TABLE IX

DISRUPTION $D$ IN THE SECOND SIMULATOR (30 SEEDS). THE B6 COLUMN GIVES $D$ WITH $T_0$ VIOLATIONS IN PARENTHESES. B4 RECORDED 0 $T_0$ VIOLATIONS; ITS ± TERM IS COMPUTED OVER THE 30 SEEDS.

| Strategy | B0 | B0-mild | B1 | B6 ($T_0$ viol.) | B7 | B4 |
|---|---|---|---|---|---|---|
| S1 | 20.0 | 4.0 | 20.0 | 19.9 (176) | 20.0 | 10.5±1.6 |
| S2 | 100.0 | 20.0 | 0.0 | 50.8 (410) | 0.0 | 0.0±0.0 |
| S3 | 60.0 | 12.0 | 60.0 | 49.1 (139) | 53.5 | 0.0±0.0 |
| S4 | 66.9 | 13.7 | 51.1 | 50.6 (625) | 0.0 | 0.0±0.0 |
| S5 | 100.0 | 20.0 | 0.0 | 50.2 (396) | 0.0 | 0.0±0.0 |
| S6 | 20.0 | 4.0 | 20.0 | 20.0 (187) | 20.0 | 10.8±3.0 |
| S7 | 60.0 | 12.0 | 10.0 | 9.3 (296) | 0.0 | 0.0±0.0 |
| S8 | 4.0 | 4.0 | 4.0 | 4.0 (183) | 4.0 | 4.0±0.1 |

### L. Added Baselines (Second Simulator)

To remove missing controls we ran a second, smaller simulator on the same 30 seeds (42–71), with $B_{\text{low}} = 2$ and $B_{\text{high}} = 8$ per 60 min. Its units and budgets differ from Section IV-A, so its values are not comparable with Tables IV and V. It adds B0-mild (B0 restricted to `revoke_sessions`, $\kappa = 0.2$), B6 (a cost budget $B_{\text{total}} = 10$ with no graph $T_0$ and no canonicalization) and B7 (one unstratified budget $B_{\text{total}} = 10$ with graph $T_0$, Agent-Lock style). Table IX gives the results. B0-mild reaches 20.0 on S2 against 0.0 for B4. B6 reaches $D \approx 50$ on S2–S5 and records $T_0$ violations under every strategy, so a cost budget without graph protection does not give the invariant. B7 matches B4 on S2, S4, S5, S7 and the adaptive attacker, but not on S3 (53.5 vs. 0.0), where it ignores dependents, nor on S1 and S6 (20.0 vs. 10.5 and 10.8). Because B7 shares graph protection with B4, it tests dependency awareness and the credibility split, not graph protection. The frozen hypotheses also predicted that B7's remediation under S7 would fall below 50%. Table IX reports disruption only, so it does not test that prediction.

### M. Analyst Sensitivity

Under S4 and the same 30 seeds, we varied the analyst false-action rate (0.02–0.30), review capacity (6–24 per day) and approval delay (2–24 h), holding the other two at 0.05,

12 per day and 4 h (Section IV-A uses an 8 h delay). SR here comes from the second simulator and is not the SR of Section IV-B, so the two should not be compared. Table X shows the results. B4's $D$ stays below B1's across the error range (1.6–20.0 vs. 49.0–53.3). B5's $D$ is lower than B4's from error 0.05 to 0.20, slightly higher at 0.02 (1.7 vs. 1.6) and roughly equal at 0.30 (20.3 vs. 20.0), but its SR is only 5.2–7.5%. B4's SR is 84.2–89.1% over the error sweep, 6.5 to 10.0 points below B1's. SR is 78.6% at 6 reviews per day, 88.5% at 12, and 98.2% from 18 on (B1: 98.1%). It falls from 90.6% at 2 h to 72.5% at 24 h. Against the frozen thresholds, the error and delay criteria are met (81.7% at 12 h) and no falsification criterion fired.

## V. Discussion

### A. Interpretation and Effectiveness

In the pilot, graph-based protection combined with credibility-split cost budgets held attacker-induced disruption to 463 units, where rate limiting allowed 6,314, and it gave up about 15.5% of rare-event remediation to do so. The more useful finding is how the effect divides. Protection stops naive attackers, budgets stop adaptive ones, stratification and the ladder matter less, and the human approver accounts for most of what is left. B4's success rate is nearly flat across a 32-fold budget range, so the remediation loss comes from routing true compromises of protected identities to people (28 misses) and from analyst error (37 misses). Faster approval for protected identities would win back some of it, and the second simulator varies exactly this wait: B4's SR falls from 90.6% at 2 h to 72.5% at 24 h (Section IV-M).

### B. Comparison with Earlier Work

The pilot agrees with the ADID report [5] in kind, since count-based and score-based gates are easy to exhaust, and with Agent-Lock [9] on the value of explicit budgets. It differs in setting (exposure feeds and deterministic playbooks) and in measuring the remediation that the guardrail gives up. The prototype audit points the same way as the simulator: a count limit that trusts caller-supplied evidence permitted hundreds of autonomous actions per day.

### C. Limitations and Threats to Validity

**Construct:** attacks are simulated and the analyst model is assumed. **Internal:** organizations are synthetic; the graph and tags are assumed correct; $\tau$ was calibrated on the benign stream; B0–B3 re-implement a static list; the H2 thresholds were not frozen in a dated commit; revision hypotheses are in `HYPOTHESES.md` (commit 018d18e, aligned in 7e99f0a); the added baselines and sensitivity sweeps use a second simulator with different units and budgets that is not merged with the main pilot; and one author wrote both the simulator and the paper, so independent replication would help. **External:** one generator family (two topologies), no real topology (LANL [29]), no real labels (GUIDE [13]) and an assumed lag distribution. **Statistical:** 30 seeds and 572 rare events; intervals are over seeds, not over organizations. **Implementation:** log keys are local unless externally witnessed; Python speeds are not production speeds; the stall rule is not simulated. **Cryptography:** only Ed25519 heads are claimed, and a Merkle log supports audit evidence but is not compliance. The pitfalls cataloged in [27] (sampling bias, label quality, baselines, base rates) apply to the synthetic pilot, which is why we label it as such.

### D. Practical Implications

Operators should (i) derive protection from graph position and attributes, and add VIP tags; (ii) denominate budgets in cost rather than action counts, and keep evidence server-side; (iii) publish log heads externally; and (iv) treat the analyst approval step as part of the attack surface.

## VI. Conclusion and Future Work

Automation that consumes exposure feeds inherits the weaknesses of those feeds. Protection derived from the graph, together with disruption budgets split by credibility, bounds what an attacker can cause by construction (given correct canonicalization, $T_0$ and dependency data) and keeps room for corroborated events, while the additive explanation and the verifiable log make each decision reviewable. In the synthetic pilot (eight attackers, six defenses) the guardrail cut attacker-induced disruption by 92.7% relative to rate limiting, paid for with a 15.5% relative loss of rare-event remediation, and the analyst emerged as the main remaining risk. Hypothesis H2 is partly met (disruption yes; 76.5% of B0's remediation against the 80% target). A second simulator shows that the disruption advantage over a static list persists up to analyst error 0.30, while B4's remediation falls to 78.6% at 6 reviews per day and 72.5% at a 24 h delay.

Next steps are (i) RQ1 on real labels: GUIDE with a temporal split and a shuffled-label leakage audit, KEV with EPSS (label: added to KEV within 90 days), LANL red-team ranking against degree, PageRank and betweenness, and the real breach-to-listing lag distribution from the HIBP catalog; (ii) attribute-based VIP protection in $T_0$; (iii) a cryptographically bound approval channel to harden the human step; (iv) a simulated stall detector; and (v) measuring how corroboration cost sets $q$.

## Ethics, Data, and Code Availability

No real leaked passwords are used. Third-party data, when added, must respect its terms (GUIDE is released under CDLA-2.0 [13]). Attack strategies are described at the model level, and no live attack tooling is released. The simulators, tests and scripts that regenerate every table and figure are in the project repository,[https://github.com/Rudrakathoke2006/idealab] (commits 018d18e, 7e99f0a and aa089bc).

## Acknowledgment

Generative AI tools assisted with parts of the drafting and language editing, with figure preparation and with document assembly, as IEEE policy asks authors to disclose. The authors are responsible for all content.

TABLE X
ANALYST SENSITIVITY IN THE SECOND SIMULATOR (S4; $D$ IN COST UNITS, SR IN %)

| Error | B1 $D$ | B1 SR | B4 $D$ | B4 SR | B5 $D$ | B5 SR |
|---|---|---|---|---|---|---|
| 0.02 | 49.0 | 99.1 | 1.6 | 89.1 | 1.7 | 7.5 |
| 0.05 | 49.8 | 98.1 | 3.6 | 88.5 | 3.1 | 6.9 |
| 0.10 | 50.3 | 95.7 | 7.3 | 87.7 | 6.1 | 6.4 |
| 0.15 | 51.1 | 94.5 | 10.6 | 86.5 | 8.6 | 6.0 |
| 0.20 | 51.6 | 93.6 | 14.0 | 85.8 | 12.1 | 6.0 |
| 0.30 | 53.3 | 90.7 | 20.0 | 84.2 | 20.3 | 5.2 |

| Cap./day | B1 | B4 | B5 |
|---|---|---|---|
| 6 | 93.6 | 78.6 | 3.6 |
| 12 | 98.1 | 88.5 | 6.9 |
| 18 | 98.1 | 98.2 | 11.9 |
| 24 | 98.1 | 98.2 | 17.9 |

| Delay | B1 | B4 | B5 |
|---|---|---|---|
| 2 h | 98.1 | 90.6 | 8.1 |
| 4 h | 98.1 | 88.5 | 6.9 |
| 8 h | 98.1 | 85.4 | 5.8 |
| 12 h | 98.1 | 81.7 | 3.9 |
| 18 h | 96.1 | 76.4 | 2.6 |
| 24 h | 77.5 | 72.5 | 0.6 |

## APPENDIX A
## PROOFS

**Proposition 1.** $R$ is linear, so $\mathsf{E}[R(X)] = R(\bar{f})$ and $R(x) - R(\bar{f}) = \sum_j w_j(f_j - \bar{f}_j)$. By the efficiency property of Shapley values with an interventional background, $\sum_j \phi_j = p(x) - \mathsf{E}[p]$. Hence $S(x) - \text{base} = \alpha(R(x) - R(\bar{f})) + (1-\alpha)100(p(x) - \mathsf{E}[p]) - m(x) = \sum_j \Phi_j - m(x)$. In floating point, the residual is the round-off of float32 predictions.

**Proposition 2.** By induction on admissions, which are processed one at a time. Canonical identities in $T_0$ are rejected by the protection check. An admission requires that the tier's windowed total plus the new cost stay within $B_{\text{tier}}$, so each window holds at most $B_{\text{tier}}$ per tier, and the two tiers sum to $B_{\text{high}} + B_{\text{low}}$. Step-up actions face the same check.

**Proposition 3.** Forged low-credibility events consume at most $B_{\text{low}}$. Forged high-credibility events consume at most $qB_{\text{high}}$ by the definition of $q$. That leaves at least $(1-q)B_{\text{high}}$ for events that are not forged.

**Proposition 4.** If edge traversals are independent, $P(\text{reach}) \geq P(\text{all edges of the best path succeed}) = \prod_{e \in \pi^*} p_e = r(i, c)$, because success of the whole path implies reach.

**Worked example (illustrative, not data).** Take weights $w = (0.6, 0.4)$, $x = (8, 6)$, $\bar{f} = (5, 5)$, $\alpha = 0.4$, $p(x) = 0.90$, $\mathsf{E}[p] = 0.50$, $\phi = (0.25, 0.15)$ and $m = 12$. Then $R(x) = 72$, $R(\bar{f}) = 50$, $S = 0.4 \cdot 72 + 0.6 \cdot 100 \cdot 0.90 - 12 = 70.8$ and $\text{base} = 0.4 \cdot 50 + 0.6 \cdot 100 \cdot 0.5 = 50$. Also $\Phi_1 = 22.2$ and $\Phi_2 = 10.6$, so $50 + 22.2 + 10.6 - 12 = 70.8 = S$.

## REFERENCES


[1] K. Thomas, F. Li, A. Zand, J. Barrett, J. Ranieri, L. Invernizzi, Y. Markov, O. Comanescu, V. Eranti, A. Moscicki, D. Margolis, V. Paxson, and E. Bursztein, "Data breaches, phishing, or malware? Understanding the risks of stolen credentials," in *Proc. ACM Conf. Comput. Commun. Secur. (CCS)*, 2017.

[2] "Have I Been Pwned API v3 documentation," https://haveibeenpwned.com/API/v3.

[3] P. Ranade, A. Piplai, S. Mittal, A. Joshi, and T. Finin, "Generating fake cyber threat intelligence using transformer-based models," in *Proc. Int. Joint Conf. Neural Netw. (IJCNN)*, 2021, pp. 1–9.

[4] S. Shafee *et al.*, "False alarms, real damage: Adversarial attacks using LLM-based models on text-based cyber threat intelligence systems," arXiv:2507.06252, 2025.

[5] M. Enriquez, "Autonomous defense induced disruption: How AI-driven automated response can be manipulated to disrupt enterprise operations," SANS Institute, White paper, May 2026.

[6] F. Jalalvand, M. Baruwal Chhetri, S. Nepal, and C. Paris, "Alert prioritisation in security operations centres: A systematic survey on criteria and methods," *ACM Comput. Surv.*, vol. 57, no. 2, pp. 1–36, 2025.

[7] S. Ndichu, A. Yamada, T. Ban, S. Ozawa, T. Takahashi, and D. Inoue, "AI-driven security alert screening and alert fatigue mitigation in security operations centers: A comprehensive survey," arXiv:2605.08316, 2026.

[8] G. Engelberg *et al.*, "AI native asset intelligence," arXiv:2605.09115, 2026.

[9] S. Addington, "Bounded autonomy in the SOC: Mitigating hallucinations in agentic incident response via neurosymbolic guardrails," in *Proc. NDSS Workshop on SOC Operations and Construction (WOSOC)*, 2026.

[10] R. Meier, C. Scherrer, D. Gugelmann, V. Lenders, and L. Vanbever, "FeedRank: A tamper-resistant method for the ranking of cyber threat intelligence feeds," in *Proc. Int. Conf. Cyber Conflict (CyCon)*, 2018, pp. 321–344.

[11] L. Huang and Q. Zhu, "RADAMS: Resilient and adaptive alert and attention management strategy against informational denial-of-service (IDoS) attacks," *Comput. Secur.*, vol. 121, p. 102844, 2022.

[12] B. Biggio and F. Roli, "Wild patterns: Ten years after the rise of adversarial machine learning," *Pattern Recognit.*, vol. 84, pp. 317–331, 2018.

[13] S. Freitas *et al.*, "AI-driven guided response for security operation centers with Microsoft Copilot for Security," arXiv:2407.09017, 2024.

[14] S. V. Poinkar and M. Kazi, "An explainable AI-based alert triage framework for security operations centres: Architecture, evaluation, and analyst-centred design," *Iraqi J. Data Sci.*, vol. 3, no. 2, pp. 67–78, 2026.

[15] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," *Digit. Threats: Res. Pract.*, vol. 2, no. 3, pp. 1–17, 2021.

[16] CISA, "Known exploited vulnerabilities catalog," https://www.cisa.gov.

[17] X. Ou, S. Govindavajhala, and A. W. Appel, "MulVAL: A logic-based network security analyzer," in *Proc. USENIX Security Symp.*, 2005.

[18] E. Purvine *et al.*, "A graph-based impact metric for mitigating lateral movement cyber attacks," in *Proc. ACM Workshop Autom. Decis. Making Active Cyber Defense (SafeConfig)*, 2016.

[19] S. Tyagi and G. Murugesan, "Measuring ransomware lateral movement susceptibility via privilege-weighted adjacency matrix exponentiation," arXiv:2508.21005.

[20] R. Gangupantulu, T. Cody, A. Rahman, C. Redino, R. Clark, and P. Park, "Crown jewels analysis using reinforcement learning with attack graphs," arXiv:2108.09358.

[21] S. A. Crosby and D. S. Wallach, "Efficient data structures for tamper-evident logging," in *Proc. USENIX Security Symp.*, 2009.

[22] B. Laurie *et al.*, "Certificate transparency," IETF RFC 6962, 2013.

[23] Z. Xiao, J. Sun, and J. Chen, "AIR: Improving agent safety through incident response," in *Proc. Int. Conf. Mach. Learn. (ICML), PMLR vol. 306*, 2026, arXiv:2602.11749.

[24] S. M. Lundberg and S.-I. Lee, "A unified approach to interpreting model predictions," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2017.

[25] S. M. Lundberg *et al.*, "From local explanations to global understanding with explainable AI for trees," *Nature Mach. Intell.*, 2020.

[26] I. E. Kumar, S. Venkatasubramanian, C. Scheidegger, and S. Friedler, "Problems with Shapley-value-based explanations as feature importance measures," in *Proc. Int. Conf. Mach. Learn. (ICML)*, 2020.

[27] D. Arp *et al.*, "Dos and don'ts of machine learning in computer security," in *Proc. USENIX Security Symp.*, 2022.

[28] B. Laurie, E. Messeri, and R. Stradling, "Certificate transparency version 2.0," IETF RFC 9162, 2021.

[29] A. Kent, "Comprehensive, multi-source cyber-security events," Los Alamos National Laboratory, https://csr.lanl.gov/data/cyber1/, 2015.